Регламент выпуска и жизненного цикла сертификатов EVT PRE 20

Ревизия A. Дата 16 октября 2026 года. Проект Дионея.

RU: Документ задаёт полный управляемый порядок выпуска, проверки, установки, ротации, отзыва, резервного копирования и восстановления сертификатов для 40 полевых станций DIO-EVT-001...040 и стендовой станции DIO-EVT-B01. Закрытые ключи, pairing secret, engineer key и пароли в документ и производственный архив не включаются.

EN: This document defines the controlled end-to-end process for issuance, verification, installation, rotation, revocation, backup and recovery of certificates for forty field stations DIO-EVT-001...040 and the bench station DIO-EVT-B01. Private keys, pairing secrets, engineer keys and passwords are excluded from this document and the production archive.

1 Статус и границы

RU: Программный PKI-процесс и инструменты выпущены для EVT. Генерация ключа полевой станции выполняется на станции или изолированной EOL-оснастке. Серверная генерация station key разрешена только для DIO-EVT-B01. Привязка к реальному BG95, аппаратное удаление временных ключей и окончательная производственная блокировка подтверждаются на собранной B01. До этого соответствующие пункты имеют статус HARDWARE VALIDATION PENDING и не получают PASS.

EN: The PKI software flow and tools are released for EVT. A field-station key is generated on the station or on an isolated EOL fixture. Server-side station-key generation is allowed only for DIO-EVT-B01. Binding to the physical BG95, hardware-backed removal of temporary keys and final production locking must be verified on the assembled B01. Until then these items remain HARDWARE VALIDATION PENDING and cannot receive PASS.

2 Роли и разделение доверия

Роль Role	Ответственность Responsibility	Доступ Access
Владелец Root CA Root CA custodian	Выпуск и хранение корня, подпись issuing CSR Root custody and issuing CSR signing	Offline root key под двойным контролем
Администратор PKI PKI administrator	Issuing CA, реестр, CRL, ACL, audit Issuing CA, registry, CRL, ACL and audit	Защищённый сервер PKI
Оператор EOL EOL operator	CSR, загрузка cert chain и station key, receipt CSR, loading and evidence	Изолированное рабочее место одной станции
Контролёр Reviewer	Проверка serial, fingerprint, chain, сроков и evidence Independent checks	Публичные сертификаты и редактированные журналы
Монтажник Installer	Сканирование QR, commissioning и read back QR scan and commissioning	Только station package в течение операции

RU: Root CA private key, issuing CA private key, command signing private key, firmware release private key, Android keystore и station private keys не передаются фабрике печатных плат и не хранятся в Git.

EN: The Root CA private key, issuing CA private key, command-signing private key, firmware-release private key, Android keystore and station private keys are never sent to the PCB factory and are never stored in Git.

3 Предварительный контроль

1. RU: Зафиксировать исходный Git commit, release ID, версии Python и cryptography, серийный номер изделия и двух операторов. EN: Record the source Git commit, release ID, Python and cryptography versions, station serial and two operators.
2. RU: Проверить, что используется действующий реестр, а не новый пустой каталог. EN: Confirm that the active registry is used and that a new empty PKI directory was not created.
3. RU: Выполнить pki list и pki audit. Сверить serial, station ID, lot и tenant. EN: Run pki list and pki audit and compare serial, station ID, lot and tenant.
4. RU: Проверить сроки root, issuing, server certificate и CRL. Просроченный CRL блокирует клиентов. EN: Check the validity of the root, issuing and server certificates and the CRL. An expired CRL blocks clients.
5. RU: Проверить bundle.json, MQTT host dioneya.ru, port 8883, server fingerprint и ca reference. EN: Verify bundle.json, MQTT host dioneya.ru, port 8883, server fingerprint and CA reference.
6. RU: Не вводить секреты в историю PowerShell, скриншоты, traveller или обычный журнал. EN: Do not place secrets in PowerShell history, screenshots, the traveller or an ordinary log.

4 Первичное создание PKI

RU: Этот раздел выполняют один раз. Если действующие Root CA и Issuing CA уже существуют, команды root init и issuing request повторно не выполняют.

EN: This section is performed once. If the active Root CA and Issuing CA already exist, do not repeat root init or issuing request.

```
python -m pki.offline_tool root-init --out <OFFLINE_ROOT>
python -m pki.cli issuing-request
python -m pki.offline_tool issuing-sign --root <OFFLINE_ROOT>/root --csr issuing.csr.pem --out
issuing.crt.pem
python -m pki.cli issuing-install --cert issuing.crt.pem --root-cert root.crt.pem
python -m pki.cli server-cert --dns dioneya.ru --dns mqtt
python -m pki.cli bridge-cert
python -m pki.cli crl
python -m pki.cli mosquitto-acl --out deploy/mosquitto/station_acl.conf
python -m pki.cli bundle --mqtt-host dioneya.ru --mqtt-port 8883
```

RU: После создания проверить цепочку, SAN сервера, fingerprint, права доступа к ключам, CRL и TLS запуск брокера. Root key возвращают в offline хранилище. EN: After creation verify the chain, server SAN values, fingerprint, key permissions, CRL and broker TLS startup. Return the root key to offline custody.

5 Реестр 41 станции

RU: Реестр содержит DIO-EVT-001...040 со station ID 1...40 и DIO-EVT-B01 со station ID 901. Серийные номера 9001...9040 принадлежат цифровым двойникам и физическим изделиям не назначаются.

EN: The registry contains DIO-EVT-001...040 with station IDs 1...40 and DIO-EVT-B01 with station ID 901. IDs 9001...9040 are reserved for digital twins and must not be assigned to physical units.

```
python -m pki.cli station-add --all-lots
python -m pki.cli list
python -m pki.cli audit --limit 200
```

RU: station add выполняют один раз. Duplicate или изменённый serial является ошибкой и требует разбора, а не создания второй записи. EN: Run station add once. A duplicate or changed serial is an error that requires investigation, not a second registry record.

6 Выпуск сертификата полевой станции

1. RU: На изолированном EOL-компьютере создать отдельный каталог по serial с ограниченным NTFS ACL. EN: Create a separate serial-specific directory on the isolated EOL computer and restrict it with NTFS ACLs.
2. RU: Сгенерировать ECDSA P-256 private key и CSR штатным инструментом. EN: Generate the ECDSA P-256 private key and CSR with the released tool.
   ```
   python 05_EOL_TOOLS/generate_evt_station_csr.py <SERIAL> --out C:/Dioneya-EOL/<SERIAL>
   ```
3. RU: Проверить код возврата 0, CN, подпись CSR и SHA-256. На сервер передать только CSR. EN: Require exit code 0 and verify the CN, CSR signature and SHA-256. Transfer only the CSR to the server.
4. RU: Подписать CSR. EN: Sign the CSR.
   ```
   python -m pki.cli station-sign <SERIAL> --csr <SERIAL>.csr.pem
   ```
5. RU: Сформировать пакет и этикетку. EN: Export the station package and label.
   ```
   python -m pki.cli station-package <SERIAL> --out <CONTROLLED_EOL_OUTPUT>
   python -m pki.cli label-qr <SERIAL> --out <CONTROLLED_LABEL_OUTPUT> --png
   python -m pki.cli server-qr --out <CONTROLLED_SERVER_QR_OUTPUT> --https-port 443 --png
   ```
6. RU: Проверить certificate, key и chain штатным инструментом. EN: Verify the certificate, key and chain with the released tool.
   ```
   python 05_EOL_TOOLS/verify_evt_station_certificate.py <SERIAL> --key <SERIAL>.key.pem --cert
   station.crt.pem --ca-chain ca-chain.pem
   ```
7. RU: Ожидаемый итог содержит PASS, правильный serial и lot, fingerprint, даты действия, Dioneya Issuing CA 1 и Dioneya Root CA. EN: The expected result contains PASS, the correct serial and lot, fingerprint, validity dates, Dioneya Issuing CA 1 and Dioneya Root CA.
8. RU: Любое несовпадение даёт FAIL. Нельзя заменять файл сертификатом или ключом другой станции. EN: Any mismatch is a FAIL. Never substitute a certificate or key from another station.

7 Стендовая станция B01

RU: Только для DIO-EVT-B01 допускается серверная генерация station key.

EN: Server-side station-key generation is allowed only for DIO-EVT-B01.

```
python -m pki.cli station-add DIO-EVT-B01 --note "EVT bench"
python -m pki.cli station-keygen DIO-EVT-B01 --allow-server-side-key
python -m pki.cli station-package DIO-EVT-B01 --out <CONTROLLED_EOL_OUTPUT>
python -m pki.cli label-qr DIO-EVT-B01 --out <CONTROLLED_LABEL_OUTPUT> --png
```

RU: Повторный station keygen без оформленного revoke и reissue запрещён. Закрытый ключ B01 передают на EOL-место защищённым каналом и не помещают в Git, общий каталог или паспорт изделия.

EN: Repeating station keygen without an approved revoke-and-reissue procedure is prohibited. Transfer the B01 private key to the EOL workstation through a protected channel and never place it in Git, a shared directory or the product passport.

8 Запись идентичности и TLS материала

1. RU: Через изолированный TEST UART выполнить factoryid с правильным serial и pairing secret из station package. EN: Use the isolated TEST UART to run factoryid with the correct serial and pairing secret from the station package.
2. RU: Выполнить холодный перезапуск и read back только признаков serial и pairing set. EN: Perform a cold reboot and read back only the serial and pairing-set indicators.
3. RU: Сформировать station secrets с ICCID и command public key. EN: Export station secrets with ICCID values and the command public key.

   ```
   python -m pki.cli station-secrets <SERIAL> --out <CONTROLLED_OUTPUT> --iccid1 <ICCID1> --iccid2 <ICCID2>
   --command-signing-key <COMMAND_PUBLIC_KEY>
   ```
4. RU: Загрузить CA, client certificate и client key в BG95. Проверить size, checksum, QFLST, QSSLCFG и успешный mTLS handshake. EN: Load the CA, client certificate and client key into BG95. Verify size, checksum, QFLST, QSSLCFG and a successful mTLS handshake.
5. RU: Пересоздать ACL и CRL, перезапустить broker по регламенту, проверить heartbeat, event receipt и command ACK. EN: Regenerate the ACL and CRL, restart the broker under the operating procedure, and verify heartbeat, event receipt and command ACK.
6. RU: После полного EOL отметить commissioning. EN: Mark commissioning only after full EOL.

   ```
   python -m pki.cli station-commission <SERIAL> --detail "<EOL record>"
   ```

9 Ротация и отзыв

RU: Причина обязательна. Сначала отозвать старый сертификат, обновить CRL и ACL и убедиться, что старый сертификат больше не подключается. Затем создать новый private key и CSR, подписать новый сертификат, повторить загрузку в BG95 и полный сетевой тест.

EN: A reason is mandatory. Revoke the old certificate first, refresh the CRL and ACL and confirm that the old certificate can no longer connect. Then create a new private key and CSR, issue the replacement certificate, reload BG95 and repeat the full network test.

```
python -m pki.cli station-revoke <SERIAL> --reason "<APPROVED_REASON>"
python -m pki.cli crl
python -m pki.cli mosquitto-acl --out deploy/mosquitto/station_acl.conf
```

RU: Утрата этикетки требует pairing secret rotate, печати новой этикетки, обновления станции, cold boot и нового LESC pairing. EN: A lost label requires pairing-secret rotation, a new label, station update, cold boot and new LESC pairing.

```
python -m pki.cli pairing-secret-rotate <SERIAL> --reason "<APPROVED_REASON>"
```

10 Сертификаты потребителей

RU: Потребитель dioneya alert получает отдельный сертификат и только разрешённые tenants. После завершения договора сертификат отзывают и повторно выпускают CRL и ACL.

EN: A dioneya alert consumer receives its own certificate and only the approved tenants. Revoke the certificate at contract end and regenerate the CRL and ACL.

```
python -m pki.cli consumer-cert <NAME> --tenants pilot1,pilot2
python -m pki.cli consumer-revoke <NAME> --reason "<APPROVED_REASON>"
```

11 Резервное копирование и восстановление

RU: В резерв входят registry.sqlite3, issuing CA key и certificate, root certificate, server and bridge certificates, CRL, ACL, audit, operator database и release manifest. Root private key хранится отдельно минимум в двух контролируемых offline копиях. Резерв шифруется, проверяется контрольной суммой и доступен по двойному контролю.

EN: Back up registry.sqlite3, the issuing CA key and certificate, root certificate, server and bridge certificates, CRL, ACL, audit data, operator database and the release manifest. Keep at least two controlled offline copies of the root private key separately. Encrypt the backup, verify its checksum and require dual control for access.

RU: Серверный backup создают штатным скриптом. Восстановление выполняют только из проверенного архива. После восстановления проверяют целостность базы, pki list, pki audit, CRL, ACL, TLS broker, server fingerprint и подключение одной bench station. EN: Create the server backup with the released script. Restore only from a verified archive. After restore verify database integrity, pki list, pki audit, CRL, ACL, broker TLS, server fingerprint and one bench-station connection.

```
deploy/scripts/backup_ubuntu.sh <ARCHIVE>
deploy/scripts/restore_ubuntu.sh <ARCHIVE>
deploy/scripts/backup_windows.ps1 -Destination <PATH>
deploy/scripts/restore_windows.ps1 -Archive <ARCHIVE>
```

12 Аварийные сценарии

Событие Event	Обязательное действие Required action	Результат Gate
Потерян station private key Lost station key	Revoke, новый key и CSR, reissue, BG95 reload, full network test	HOLD до полного evidence
Скомпрометирован issuing key Issuing key compromised	Изолировать сервер, уведомить владельца Root CA, новый issuing CA, массовый controlled reissue	STOP ISSUE
Истёк CRL CRL expired	Выпустить CRL, проверить срок, перезапустить broker, проверить bench connection	Broker release blocked
Утеряна этикетка Label lost	Rotate pairing secret, reprint, reload, cold boot, LESC check	Старый QR уничтожить
Неизвестен результат BG95 upload Unknown BG95 upload result	Удалить файл и загрузить с начала, проверить size checksum QFLST	Нельзя продолжать
Перепутаны serial и certificate Serial certificate mismatch	Изолировать изделие, revoke ошибочный cert, оформить rework	FAIL

13 Evidence и критерий завершения

RU: Для каждой станции сохранить CSR JSON без ключа, fingerprint сертификата, chain verification PASS, redacted PKI audit, ACL revision, BG95 file checks, mTLS, MQTT heartbeat, event receipt, command ACK, provisioning receipt и ссылку на EOL record. Полные ICCID, IMSI и все secret values в evidence запрещены.

EN: For each station retain the key-free CSR JSON, certificate fingerprint, chain-verification PASS, redacted PKI audit, ACL revision, BG95 file checks, mTLS, MQTT heartbeat, event receipt, command ACK, provisioning receipt and the EOL-record reference. Full ICCID, IMSI and all secret values are prohibited in evidence.

RU: Операция завершена только после независимой сверки serial, station ID, tenant, fingerprint, chain, срока, ACL, сетевого теста и удаления временных secret exports. EN: The operation is complete only after an independent check of serial, station ID, tenant, fingerprint, chain, validity, ACL, network test and removal of temporary secret exports.